Universidad Nacional de Costa Rica.

Facultad de ciencias exactas y naturales.

Instrumento de auditoría de confidencialidad para Oracle basado en ISO/IEC 27001:2022

Luis Hidalgo Calvo

Profesor: Johnny Villalobos Murillo

Administración de Bases de Datos

II Ciclo 2026.

Resumen

Este trabajo presenta un instrumento de auditoría de confidencialidad para bases de datos Oracle, orientado a relacionar riesgos, tareas del administrador, controles de seguridad y evidencia verificable. El objetivo consiste en evaluar configuraciones mediante una matriz vinculada con ISO/IEC 27001:2022 e ISO/IEC 27002:2022 y organizar su mejora mediante el ciclo Planificar, Hacer, Verificar y Actuar. Se empleó un estudio aplicado sobre la empresa ficticia Clínica Los Robles, con información sintética y registros de Oracle Database 21c Express Edition. El método integró revisión del enunciado, análisis del sistema, consulta de fuentes oficiales y examen de auditorías almacenadas. El artefacto contiene seis riesgos, doce tareas, diecinueve controles ISO y veinticuatro observables SQL. Las ejecuciones históricas comparadas conservaron cinco observables conformes y diecinueve con incumplimientos; la medición posterior del 27 de octubre registró cuatro conformes y veinte con incumplimientos. Las pruebas automatizadas disponibles finalizaron satisfactoriamente, aunque no sustituyen la comprobación de controles en Oracle. Se concluye que el instrumento permite localizar brechas y proponer acciones trazables, pero los resultados no acreditan una corrección integral del laboratorio. La efectividad debe demostrarse mediante observación y pruebas funcionales, sin considerar las marcas manuales de resolución como evidencia suficiente.

Palabras clave: confidencialidad, Oracle, auditoría, ISO/IEC 27001, administración de bases de datos.

Instrumento de auditoría de confidencialidad para Oracle basado en ISO/IEC 27001:2022

Introducción

El DBA protege la confidencialidad frente a privilegios excesivos, cuentas olvidadas, respaldos expuestos y copias de producción utilizadas en desarrollo. Para comprobar esa protección necesita evidencia verificable.

La asignación exige cinco riesgos como mínimo, doce tareas del DBA, quince controles ISO, una matriz de madurez 0–4, pruebas con scripts, metodología PHVA y declaración de IA (Villalobos Murillo, 2026). El plan v2 concreta la secuencia: observar, identificar hallazgos, proponer correctivos y reobservar.

Objetivo general. Documentar y analizar un instrumento de evaluación de controles de confidencialidad para Oracle, vinculando riesgos y tareas del DBA con evidencia técnica y acciones de mejora.

Objetivos específicos. Identificar los riesgos y tareas implementados; explicar la selección de controles ISO y sus mecanismos; describir la metodología y la escala de evaluación; contrastar resultados reales; y establecer limitaciones y prioridades de mejora.

La clínica ficticia permite estudiar datos sensibles sin utilizar información real. El alcance es una evaluación técnica parcial, no una certificación ISO.

Marco teórico

ISO/IEC 27001:2022 y gestión de riesgos

ISO/IEC 27001 establece requisitos para un sistema de gestión de seguridad de la información, mientras que ISO/IEC 27002 orienta la selección e implementación de controles

(International Organization for Standardization [ISO] & International Electrotechnical Commission [IEC], 2022a, 2022b). La revisión de 2022 reorganizó el conjunto de 114 controles de la edición anterior en 93, agrupados en cuatro temas: organizacionales, personas, físicos y tecnológicos. Incorporó atributos que facilitan examinar los controles desde distintas perspectivas (ISO/IEC JTC 1/SC 27, 2022).

La selección responde al riesgo. ISO no impone la fórmula de madurez del proyecto ni umbrales universales de cinco intentos fallidos o noventa días de contraseña. El Cybersecurity Framework 2.0 también distingue los resultados buscados de los mecanismos adoptados para alcanzarlos (National Institute of Standards and Technology [NIST], 2024).

Mínimo privilegio, separación de funciones y Zero Trust

El mínimo privilegio limita cada cuenta a las operaciones de su función; los roles facilitan administrar esos permisos. La separación de funciones distingue administración, autorización y revisión. En este instrumento, el auditor consulta metadatos y el DBA aplica las correcciones fuera de la aplicación.

La defensa en profundidad combina autorización, cifrado y auditoría. Zero Trust establece que estar dentro de una red no basta para confiar: se debe evaluar el acceso al recurso solicitado (Rose et al., 2020). El proyecto adopta estos principios sin implementar una arquitectura Zero Trust completa.

El catálogo exige una vigencia máxima de contraseña configurable. Sin embargo, NIST desaconseja cambios periódicos sin evidencia de compromiso: cumplir el catálogo no garantiza adoptar todas las recomendaciones actuales (Temoshok et al., 2025).

Cifrado, enmascaramiento y control de filas

Transparent Data Encryption —TDE— protege columnas o tablespaces frente al acceso a sus archivos. Exige custodiar el keystore y recuperar la llave maestra; perderlos puede impedir el acceso legítimo. TDE no reemplaza los permisos SQL (Oracle, s. f.-f).

Data Redaction transforma valores entregados por consultas sin cambiar los originales. El enmascaramiento estático sustituye datos por valores ficticios y resulta apropiado para clones de desarrollo. Son mecanismos distintos y deben verificarse según su propósito (Oracle, s. f.-e).

Virtual Private Database —VPD— agrega predicados a las consultas; puede limitar los expedientes al médico asignado. Una política habilitada no demuestra que filtre correctamente: deben probarse accesos permitidos y denegados, considerando cuentas exentas (Oracle, s. f.-h).

TLS y el cifrado nativo de Oracle Net protegen el tráfico mediante mecanismos distintos (Oracle, s. f.-b). python-oracledb Thin admite TLS; el cifrado nativo requiere Thick. Exigirlo sin preparar el cliente puede impedir las conexiones (Oracle, s. f.-a). OBS-20 reconoce el adaptador nativo y requiere comprobación adicional para TLS.

Fuga de datos, respaldos y registros

La prevención de fuga de datos comprende exportaciones, directorios, comunicaciones y copias. Restringir permisos contribuye a DLP, sin implementarlo integralmente. RMAN permite cifrar respaldos; además deben comprobarse su recuperación y las llaves necesarias (Oracle, s. f.-c).

Vaciar la papelera de Oracle no acredita eliminar copias ni remanentes físicos. La sanitización exige métodos adecuados al soporte y verificar sus resultados (Chandramouli & Hibbard, 2025).

La auditoría unificada registra actividad y separa administración y consulta mediante `AUDIT_ADMIN` y `AUDIT_VIEWER` (Oracle, s. f.-d). Un SIEM podría correlacionar eventos, pero el sistema no lo integra. Las alertas requieren revisión, preservación de evidencia y procedimientos de respuesta (Nelson et al., 2025).

Protección de datos en Costa Rica

La Ley N.º 8968 protege la autodeterminación informativa. Sus artículos 9–11 regulan datos sensibles, seguridad y confidencialidad (Asamblea Legislativa de la República de Costa Rica, 2011); el Decreto N.º 37554-JP desarrolla su aplicación (Presidencia de la República & Ministerio de Justicia y Paz, 2013). En la clínica, justifican proteger diagnósticos, tratamientos y copias. La auditoría técnica no evalúa integralmente consentimiento, finalidad ni todos los deberes del responsable.

Método

Se estudió el laboratorio Clínica Los Robles S.A., en `PDB_CLINICA`, Oracle 21c XE `21.3.0.0.0`. El estudiante administra y evalúa un entorno con información sintética; no participaron pacientes reales.

Se revisaron el enunciado, Semana 13, ambos planes, backend, frontend, catálogos, veinticuatro observables, seis scripts de laboratorio y evidencias almacenadas. Los apuntes de recuperación aportaron contexto, sin sustituir los requisitos de confidencialidad.

PHVA comprende **Planificar** riesgos y política; **Hacer** la configuración autorizada; **Verificar** mediante observación y comparación; y **Actuar** priorizando brechas y reobservando. La aplicación propone correcciones, pero su ejecución corresponde al DBA.

Se compararon las ejecuciones #12 y #16 y se registró #17 el 27 de octubre de 2026, a las 20:21, hora de Costa Rica. La intervención se detuvo antes de aplicar los correctivos pendientes; #17 representa el estado previo, no una corrección final.

Artefacto y criterios de evaluación

Arquitectura y alcance

React organiza el flujo de auditoría; FastAPI ejecuta el motor y SQLite conserva resultados. El catálogo externo vincula riesgos, tareas, controles y correctivos. Las consultas usan variables enlazadas y el descubrimiento analiza nombres y tipos de columnas, sin leer datos de negocio.

Fernet protege las credenciales guardadas mientras se custodie su llave (Python Cryptographic Authority, s. f.). El auditor consulta catálogos; `SELECT_CATALOG_ROLE` concede acceso amplio a metadatos. El despliegue local no acredita seguridad para un servicio público multiusuario.

Riesgos y tareas del DBA

Mapeo de controles y evidencia

Madurez y batería de pruebas

Cada fila SQL representa un hallazgo; cero filas indican conformidad dentro del alcance observado. Un error o visibilidad insuficiente produce **No evaluable**, distinto de incumplimiento.

`evaluacion.py` asigna madurez según observables conformes: 0 % → 0; menos de 50 % → 1; 50–99 % → 2; 100 % → 3. El nivel 4 requiere cobertura completa, OBS-18 y OBS-19 conformes y revisión registrada. Estados: 0–1 **No cumple**; 2 **Parcial**; 3–4 **Cumple**. Se excluyen los no evaluables del denominador y se informa la cobertura. Aceptar documentalmente todos los hallazgos puede elevar a 2, sin eliminar el riesgo.

Resultados

Se identificaron los seis componentes exigidos del artefacto. Las **136 pruebas automatizadas** existentes pasaron y la revisión estática del frontend terminó sin errores. Al utilizar conexiones simuladas, esas pruebas no acreditan la ejecución de todos los correctivos en Oracle.

Entre #12 y #16, OBS-04 mejoró y OBS-06 volvió a incumplir. En #17 aparecieron nueve cuentas sin actividad reciente bajo el umbral didáctico de **un día**. OBS-17 también depende de una ventana temporal; los conteos requieren interpretar el contexto.

La medición #17 encontró 21 concesiones directas, cuatro tablas sin VPD, quince columnas sin cifrado observado, cinco columnas del clon sin evidencia de enmascaramiento y un keystore no disponible. Persistían `DBA` en `APP_CLINICA` y `SELECT ANY TABLE` en `DEV_USER`. No existe una medición posterior a los correctivos manuales pendientes.

Discusión

El aporte principal es vincular configuración, riesgo, hallazgo y acción. Detectar una línea base insegura no demuestra haberla protegido. Las seis marcas «resuelto» de #16 fueron identificadas por el responsable como incorrectas y se excluyen como evidencia de efectividad.

El descubrimiento puede omitir datos sensibles; VPD habilitado no garantiza un filtrado correcto; un comentario no acredita enmascaramiento físico; y una purga no demuestra custodia suficiente. El promedio de madurez tampoco representa probabilidad de fuga ni cumplimiento legal.

El plan propuesto prioriza roles funcionales; VPD y enmascaramiento; recuperación de llaves, TDE y respaldos; compatibilidad del cliente y cifrado de red; y auditoría y tratamiento del riesgo de XE. El DBA y el responsable del dato deben aprobar las reglas. Cada cierre requiere reobservación y evidencia funcional; las prioridades no representan acciones ya aplicadas.

Conclusiones

El sistema implementa una evaluación repetible que relaciona seis riesgos y doce tareas con diecinueve controles y veinticuatro consultas. Su diseño permite ajustar políticas por empresa y conservar evidencia de las auditorías.

Los resultados disponibles demuestran detección de brechas y funcionamiento de los componentes probados, pero no una corrección integral. La última medición conserva veinte observables con hallazgos; cualquier afirmación posterior de mejora requiere nuevas evidencias.

El criterio profesional del DBA sigue siendo necesario para interpretar el alcance, autorizar cambios y comprobar su efectividad. Separar configuración observada, corrección propuesta y resultado verificado evita atribuir al instrumento garantías que no proporciona.

Uso de inteligencia artificial y entregables complementarios

La IA asistió a la revisión, consulta de fuentes y redacción. El estudiante preparará por separado la tabla completa de prompts, su validación crítica y la declaración firmada. El registro `tabla-uso-ia.md` debe incorporar esta intervención; no se presume su validación ni firma.

Video: Agregado el link en la entrega

Referencias

Asamblea Legislativa de la República de Costa Rica. (2011). *Ley N.º 8968: Protección de la persona frente al tratamiento de sus datos personales*. Tribunal Supremo de Elecciones. https://www.tse.go.cr/pdf/normativa/leydeprotecciondelapersona.pdf

Chandramouli, R., & Hibbard, E. (2025). *Guidelines for media sanitization* (NIST SP 800-88 Rev. 2). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-88r2

International Organization for Standardization, & International Electrotechnical Commission. (2022a). *Information security, cybersecurity and privacy protection—Information security management systems—Requirements* (ISO/IEC 27001:2022). https://www.iso.org/standard/27001

International Organization for Standardization, & International Electrotechnical Commission. (2022b). *Information security, cybersecurity and privacy protection—Information security controls* (ISO/IEC 27002:2022). https://www.iso.org/standard/75652.html

ISO/IEC JTC 1/SC 27. (2022). *SC 27 journal: Special issue on ISO/IEC 27002* (Vol. 2, N.º 2). https://committee.iso.org/files/live/sites/jtc1sc27/files/resources/ISO-IECJTC1-SC27_N22394_SC%2027%20Journal%20Volume%202%2C%20Issue%202%20-%20Special%20issue%20on%20ISO-IEC%2027002.pdf

National Institute of Standards and Technology. (2024). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile* (NIST SP 800-61 Rev. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

Oracle. (s. f.-a). *Connecting to Oracle Database*. python-oracledb documentation. https://python-oracledb.readthedocs.io/en/latest/user_guide/connection_handling.html

Oracle. (s. f.-b). *Configuring Oracle Database native network encryption and data integrity*. Oracle Database Security Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/configuring-network-data-encryption-and-integrity.html

Oracle. (s. f.-c). *Configuring the RMAN environment: Advanced topics*. Oracle Database Backup and Recovery User's Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/bradv/configuring-rman-client-advanced.html

Oracle. (s. f.-d). *Introduction to auditing*. Oracle Database Security Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/introduction-to-auditing.html

Oracle. (s. f.-e). *Introduction to Oracle Data Redaction*. Oracle Database Advanced Security Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/introduction-to-oracle-data-redaction.html

Oracle. (s. f.-f). *Introduction to transparent data encryption*. Oracle Database Advanced Security Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/asoag/introduction-to-transparent-data-encryption.html

Oracle. (s. f.-g). *Oracle Database Express Edition FAQ*. https://www.oracle.com/database/technologies/appdev/xe/faq.html

Oracle. (s. f.-h). *Using Oracle Virtual Private Database to control data access*. Oracle Database Security Guide, 21c. https://docs.oracle.com/en/database/oracle/oracle-database/21/dbseg/using-oracle-vpd-to-control-data-access.html

Presidencia de la República, & Ministerio de Justicia y Paz. (2013). *Decreto Ejecutivo N.º 37554-JP: Reglamento a la Ley de Protección de la Persona frente al Tratamiento de sus Datos Personales*. Tribunal Supremo de Elecciones. https://www.tse.go.cr/pdf/normativa/reglamentoleyproteccionpersona.pdf

Python Cryptographic Authority. (s. f.). *Fernet (symmetric encryption)*. Cryptography documentation. https://cryptography.io/en/latest/fernet/

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture* (NIST SP 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Temoshok, D., Fenton, J., Choong, Y.-Y., Lefkovitz, N., Regenscheid, A., Galluzzo, R., & Richer, J. (2025). *Digital identity guidelines: Authentication and authenticator*

management (NIST SP 800-63B-4). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-63B-4

Villalobos Murillo, J. (2026). *Controles ISO 27001:2022 para la confidencialidad en administración de bases de datos* [Enunciado de asignación, II Ciclo 2026]. Escuela de Informática, Universidad Nacional de Costa Rica. Documento proporcionado en `docs_clase/Asignacion-ISO27001-Confidencialidad-DBA-II-Ciclo-2026-UNA (1).pdf`.